

Auditable Events Standard

STANDARD NUMBER: DAS-ITS-2100-12-A	EFFECTIVE DATE: 12/22/2017	APPROVED BY: Anupam Srivastava, State Chief Information Security Officer
REPLACES STANDARD DATED: n/a	AUTHORITY: Ohio Revised Code 125.18 Office of Information Technology - duties of director - contracts, Ohio IT Standard ITS-SEC-02, "Security Controls Framework"	

1.0 Purpose

The purpose of this standard is to provide requirements to Ohio Department of Administrative Services (DAS) technical teams that will allow for the consistent implementation of auditable event standards across information systems.

2.0 Scope

The scope of this standard includes information systems that are developed or acquired by the Ohio Department of Administrative Services (DAS).

This standard represents the minimum acceptable criteria governing auditable events.

3.0 Standard

3.1 The following events shall be audited by information systems that that are developed or acquired by DAS:

- 3.1.1 Log onto system
- 3.1.2 Log off of system
- 3.1.3 Change of password
- 3.1.4 All system administrator commands, while logged on as system administrator
- 3.1.5 Switching accounts or running privileged functions from another account (e.g., Linux/Unix SU or Windows RUNAS)
- 3.1.6 Creation or modification of super user groups
- 3.1.7 Subset of security administrator commands while logged on in the security administrator role
- 3.1.8 Subset of system administrator commands while logged on in the user role
- 3.1.9 Clearing of the audit log file

- 3.1.10 Startup and shutdown of audit functions
- 3.1.11 Use of identification and authentication mechanisms (e.g., user ID and password) whenever they are required after initial login
- 3.1.12 Change of file or user permissions or privileges (e.g., use of suid/guid, chown, su)
- 3.1.13 Remote access outside of the state network communications channels (e.g., dedicated virtual private network) and all dial-in access to the system
- 3.1.14 Changes made to an application or database by a batch file
- 3.1.15 Application critical record changes
- 3.1.16 Changes to database or application records, where the application is bypassed to produce the change (via a file or other database utility)
- 3.1.17 All system and data interactions concerning confidential personal information (CPI)
- 3.1.18 Additional platform specific events may also be required, based on the outcome of the risk assessment required by DAS Policy 2100-08, "Risk Assessment."

3.2 Exception Process

To request an exception to one or more of the requirements outlined in this standard, please complete an IT Security Exception Request Form.

- 3.2.1 The form is located within the [IT Enterprise Services Portal](#) under the "Services & Products" category.
- 3.2.2 If you have questions, please contact the DAS Office of Information Security and Privacy (refer to Section 9.0 Inquires for contact information).

4.0 References

- 4.1 **Ohio IT Standard ITS-SEC-02, Security Controls Framework:** This state IT standard specifies the minimum requirements for information security in all agencies and identifies the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 as the framework for information security controls implementation for the state.
- 4.2 **National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, Security and Privacy Controls for Federal Information Systems and Organizations:** NIST SP 800-53 provides guidelines for selecting and specifying security controls for federal government information systems.
- 4.3 **DAS Policy 2100-12, Audit and Accountability Policy:** DAS Policy 2100-12 defines information system audit and accountability requirements that will assist in assessing the adequacy of system controls, ensuring compliance with

established policies and operational procedures, and uniquely tracing the actions of system users.

- 4.4 **DAS IT Standard DAS-ITS-2100-01-A, Password Standard for Organizational Users:** Provides password requirements to DAS technical teams that will allow for the consistent implementation of password standards across DAS-managed system assets for internal users (e.g., state employees, contractors, county workers, etc.).
- 4.5 **IRS Publication 1075, Tax Information Security Guidelines for Federal, State and Local Agencies:** Provides guidance to ensure the policies, practices, controls, and safeguards employed by recipient agencies, agents, or contractors adequately protect the confidentiality of federal tax information.

5.0 Definitions

<i>Audit</i>	A review and examination of information system records and activities to assess the adequacy of system controls, to ensure compliance with established policies and operational procedures, and to recommend necessary changes in controls, policies, or procedures. ¹
<i>Audit Logs</i>	A record showing who has accessed a computer system and what operations have been performed during a given time period. Audit logs are useful both for maintaining information technology security and recovering lost transactions.
<i>Confidential Personal Information (CPI)</i>	Personal information that falls within the scope of section 1347.15 of the Ohio Revised Code and that an agency is prohibited from releasing under Ohio's public records law.
<i>Information System</i>	A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. ²
<i>Privileged Functions</i>	Security-relevant functions that ordinary users are not typically authorized to perform. Privileged functions are often associated with network and/or system administrators and accounts with root-level authority.

¹ "NIST Special Publication 800-32, Introduction to Public Key Technology and the Federal PKI Infrastructure," U.S. Department of Commerce National Institute of Standards and Technology, February, 2001 <<https://csrc.nist.gov/publications/nistpubs/800-32/sp800-32.pdf>>.

² "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

User An individual or (system) process authorized to access an information system.³

6.0 Related Resources

Document Name
<i>DAS IT Operations and Management Policy 2100-01, "Password Policy"</i> https://das.ohio.gov/technology-and-strategy/policies
<i>DAS IT Standard ITS-2100-01-A, "Password Standard for Organizational Users"</i> https://das.ohio.gov/technology-and-strategy/policies
<i>Ohio IT Standard ITS-SEC-01, "Data Encryption and Cryptography"</i> https://das.ohio.gov/technology-and-strategy/policies
<i>Ohio IT Standard ITS-SEC-02, "Security Controls Framework"</i> https://das.ohio.gov/technology-and-strategy/policies
<i>NIST SP 800-53; "Security and Privacy Controls for Federal Information Systems and Organizations"</i> https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf

7.0 Implementation

- 7.1 DAS IT system managers are expected to work towards implementation of the auditable event requirements outlined in this standard as quickly as possible.
- 7.2 For new information systems that are developed or acquired by DAS, the auditable event requirements outlined in this standard shall immediately become effective.
 - 7.2.1 For existing information systems and information system development projects that have moved beyond the requirements phase, DAS IT system managers have one year from the effective date of this policy to implement the requirements.
 - 7.2.2 If for some reason a DAS IT system manager feels that it is not technically feasible to implement the auditable event requirements outlined in this standard, an exception request shall be submitted in accordance with Section 3.2.
 - 7.2.3 If for some reason a DAS data owner or service owner feels that it is not technically feasible to implement the requirements outlined in this standard, an exception request shall be submitted in accordance with Section 3.2.

³ "FIPS 200, Minimum Security Requirements for Federal Information and Information Systems." Federal Information Processing Standards Publication (FIPS) March 2006. <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.200.pdf>>.

8.0 Revision History

Date	Description of Changes
12/22/2017	Original Standard
11/28/2018	Updated the exception request language to align with the current procedure.
02/24/2020	Updated standard template.
06/22/2021	Conducted routine maintenance review of citations and references.
06/22/2022	Scheduled standard review.

9.0 Inquiries

For information regarding this DAS IT standard, please contact:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 19th Floor
Columbus, Ohio 43215

Telephone: 614.644.9391

Email: state.isp@das.ohio.gov

Web: <https://das.ohio.gov/technology-and-strategy/information-security-privacy>

DAS IT Standards are online at:

<https://das.ohio.gov/technology-and-strategy/policies>

10.0 Attachments

None.